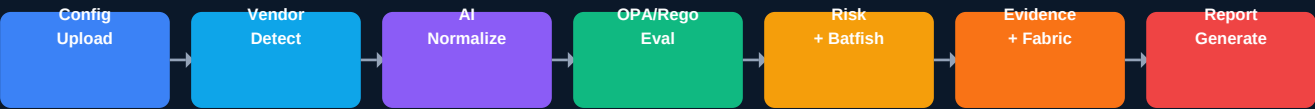


NetSecAuditor

AI-Driven Multi-Vendor Network Security Compliance Auditor

Ingests network configs (Cisco · Juniper · Fortinet · Palo Alto · Arista · SONiC), normalises them into a vendor-agnostic Security Baseline Model, evaluates every control with a deterministic rule engine (OPA/Rego), and produces signed, blockchain-anchored compliance reports — with local AI filling in gaps the parsers can't reach.

Processing Pipeline (per uploaded/collected config)



Core Components

FRONTEND	React + Vite + Tailwind	SOC dashboard with real-time pipeline progress, Monaco config viewer, findings table, training center, and evidence ledger.
API	FastAPI (Python)	REST API with JWT/RBAC auth, multi-tenancy, WebSocket polling, and full OpenAPI docs at /docs.
MSG BUS	NATS JetStream	Decouples ingestion from the analysis pipeline. Background workers subscribe to scan events.
AI / RAG	Ollama · Qwen3-8B · BGE-M3 · pgvector	Interprets configuration syntax the deterministic parsers don't recognise. Confidence ≥ 0.75 auto-applies; lower routes to Training Center for human sign-off. Falls back to keyword heuristics when no GPU is present.
PARSERS	Deterministic Rule Engine	Per-vendor rule lists (Cisco IOS-XE/NX-OS, Juniper Junos, Fortinet FortiOS, PAN-OS, Arista EOS, SONiC). Vendor auto-detected by signature matching. New vendors add in one file.
POLICY OPA	OPA / Rego + Python	The only path that issues PASS/FAIL. Evaluates CIS · NIST SP 800-53 · DISA STIG · ISO 27001 controls against the validated Baseline Model — raw AI text never reaches this layer.
BATFISH	Batfish Behavioral Analysis	Answers what OPA structurally can't: Guest→Mgmt reachability, ACL shadowing, default-route exposure. Results feed the risk engine.
STORAGE	PostgreSQL + pgvector · MinIO · OpenBao	Findings and baselines in Postgres. Raw configs/reports in MinIO (S3-compatible). Secrets (device creds) in OpenBao — never in Postgres.
BLOCKCHAIN	Hyperledger Fabric	Evidence anchored on a permissioned ledger (SHA-256 hash + decision only — zero raw config on-chain). Best-effort; scan result never blocked if Fabric is unavailable.
OBSERV.	VictoriaMetrics + Grafana	OpenTelemetry-ready metrics stack. Grafana pre-wired at :3001.

Design Principles

◆ LLM never decides compliance

OPA + Rego is the sole PASS/FAIL authority. AI confidence only controls auto-apply vs. Training Center routing.

◆ Deterministic fallback always runs

Keyword-similarity parsers ensure full pipeline operation even with no GPU / no Ollama models pulled.

◆ Credentials never touch the DB

Device secrets live exclusively in OpenBao. Only a credential_ref UUID appears in Postgres.

◆ Immutable evidence chain

Every scan, rerun, and remediation produces a new, append-only evidence record. Nothing is ever overwritten.

◆ Multi-tenant by default

Every DB row carries a tenant_id. No cross-tenant data is ever visible, even in list endpoints.

◆ New vendor in one file

Add detection signatures + rule list in vendor_detect.py / parsers.py. Everything else — OPA, reports, training, remediation — is already vendor-agnostic.

Quick Start & Deployment

docker compose up --build

Full stack: Postgres, pgvector, MinIO, NATS, OPA, Battfish, Ollama, Keycloak, OpenBao, backend, frontend, Grafana, VictoriaMetrics + seed data.

Ports: :5173 (UI) · :8000 (API) · :3001 (Grafana) · :9001 (MinIO) · :8081 (Keycloak)

Local dev (no Docker):

cd backend && uvicorn app.main:app --reload | Falls back to SQLite automatically when Postgres is unreachable.

Ollama models (first-run only):

docker exec compliance-ollama ollama pull qwen3:8b && ollama pull bge-m3

Hyperledger Fabric (optional):

make fabric-up && make fabric-deploy | FABRIC_ENABLED=false disables anchoring with zero code changes.

100% free/open-source · Self-hostable · No paid cloud APIs required · Problem Statement: SIH 26155